

# Enci/ VENTAS

## Matriz de Endpoints y Contratos API

ANEXO C

Proyecto Enci / Enci Ventas

*Aplicación de Automatización de Fuerza de Ventas*

Equipo de Desarrollo: Grupo PLM - Universidad Tecnológica Metropolitana

Líder: Joshua Flores

Integrantes: Falon Berrios, Carolaine Palacios y Eliseo Poblete

Versión 1.0

Julio 2026

## Tabla de Contenidos

1. Introducción y propósito
2. Convenciones generales de consumo API
3. Seguridad, autenticación y autorización
4. Matriz consolidada de endpoints
5. Endpoints de salud, ambiente y usuario actual
6. Contratos de autenticación
7. Contratos del módulo Clientes
8. Contratos del flujo comercial
9. Contratos de dashboard y analítica
10. Contratos de usuarios, roles y preferencias
11. Contratos de competencia e inteligencia comercial
12. Contratos del módulo IA RAG
13. Consola Swagger / OpenAPI y documentación técnica
14. Parámetros, modelos y validaciones transversales
15. Errores esperados y respuestas de control
16. Matriz de trazabilidad por módulo
17. Criterios de aceptación del anexo

## 1. Introducción y propósito

Este anexo formaliza la matriz de endpoints y contratos API del sistema Enci / Enci Ventas. Su objetivo es dejar documentadas las rutas expuestas por el backend FastAPI, las condiciones de autenticación, los roles requeridos, los parámetros aceptados, los payloads principales, los códigos de respuesta esperados y los criterios mínimos para pruebas de integración, UAT y soporte técnico.

La matriz se construye para facilitar la recepción técnica del sistema, la ejecución de pruebas en Swagger/OpenAPI, la integración de frontend web, PWA vendedor, app móvil Flutter parcialmente realizada y cualquier consumidor autorizado que opere contra la API. El documento también diferencia endpoints de desarrollo, endpoints de administración, endpoints de negocio y endpoints asociados al componente RAG parcial.

### Criterio de lectura

La API debe entenderse como la autoridad de negocio y seguridad. El frontend, la PWA o la app Flutter consumen endpoints, pero no sustituyen las validaciones de token, rol, plataforma, estado activo ni propiedad de registros que ejecuta el backend.

### 1.1 Responsables del documento

| Campo                    | Detalle                                             |
|--------------------------|-----------------------------------------------------|
| Proyecto                 | Enci / Enci Ventas                                  |
| Tipo de documento        | Anexo técnico - matriz de endpoints y contratos API |
| Repositorio técnico base | Repositorio oficial Enci (monorepo)                 |
| Equipo responsable       | Grupo PLM - Universidad Tecnológica Metropolitana   |
| Líder                    | Joshua Flores                                       |
| Integrantes              | Falon Berrios, Carolaine Palacios y Eliseo Poblete  |
| Versión                  | 1.0                                                 |
| Fecha                    | Julio 2026                                          |

## 2. Convenciones generales de consumo API

Los endpoints protegidos requieren que el consumidor envíe un ID Token emitido por Firebase Auth en el header Authorization. El backend valida dicho token con Firebase Admin y luego consulta Firestore para resolver rol, estado activo, plataforma habilitada y datos operativos del usuario.

### 2.1 Header de autenticación

```
Authorization: Bearer <firebase_id_token>
```

## 2.2 Header de plataforma

El backend interpreta el origen funcional del cliente mediante X-Enci-Client. Si el header no se informa, se asume web. Para consumidores móviles, el valor puede informarse como mobile, movil, app, app\_movil o app-movil, todos normalizados internamente como mobile.

```
X-Enci-Client: web
X-Enci-Client: mobile
```

| Valor recibido              | Normalización | Campo evaluado en users/{uid} | Uso                                           |
|-----------------------------|---------------|-------------------------------|-----------------------------------------------|
| web / vacío                 | web           | webApp                        | Frontend web React/Vite y consola de pruebas. |
| mobile                      | mobile        | appMovil                      | PWA vendedor o app móvil autorizada.          |
| movil                       | mobile        | appMovil                      | Alias de cliente móvil.                       |
| app / app_movil / app-movil | mobile        | appMovil                      | Alias de cliente móvil.                       |

## 2.3 Formato de datos

- Los payloads de negocio se envían en JSON, salvo importación CSV y carga documental RAG, que usan multipart/form-data.
- Las fechas deben enviarse en formato compatible con datetime ISO 8601 cuando el contrato lo exija.
- Los campos no declarados en modelos Pydantic se rechazan mediante extra=forbid en los contratos críticos de entrada.
- Los endpoints de listado usan límites controlados mediante query params con topes definidos por backend.
- Los nombres técnicos de parámetros respetan camelCase en los contratos de frontend cuando corresponde: clientId, vendedorUid, oportunidadId.

## 3. Seguridad, autenticación y autorización

La protección de endpoints se basa en una secuencia obligatoria: token válido, usuario registrado, usuario activo, rol suficiente, acceso a plataforma y propiedad del registro cuando aplica. Esta secuencia evita que la seguridad dependa de ocultar botones o rutas en el frontend.

| Control            | Aplicación                                                     | Respuesta esperada si falla             |
|--------------------|----------------------------------------------------------------|-----------------------------------------|
| Token Firebase     | Todos los endpoints protegidos validan Authorization Bearer.   | 401 Token inválido o expirado.          |
| Usuario registrado | El UID debe existir o quedar sincronizado según flujo de auth. | 403 Usuario no registrado o sin acceso. |
| Activo             | users/{uid}.activo debe ser true.                              | 403 Usuario inactivo.                   |

| Control    | Aplicación                                                         | Respuesta esperada si falla                   |
|------------|--------------------------------------------------------------------|-----------------------------------------------|
| Rol        | require_role valida admin, supervisor o vendedor según endpoint.   | 403 Permisos insuficientes.                   |
| Plataforma | webApp o appMovil deben estar habilitados según X-Enci-Client.     | 403 Usuario sin acceso a web app o app móvil. |
| Propiedad  | Vendedor solo opera registros propios.                             | 403 No tienes permisos para este registro.    |
| Payload    | Modelos Pydantic validan tipos, rangos, longitudes y campos extra. | 422 Payload inválido.                         |

### 3.1 Jerarquía de roles

| Requerimiento declarado    | Roles que pasan             |
|----------------------------|-----------------------------|
| require_role('admin')      | admin                       |
| require_role('supervisor') | admin, supervisor           |
| require_role('vendedor')   | admin, supervisor, vendedor |

## 4. Matriz consolidada de endpoints

La siguiente matriz consolida la superficie funcional de la API. Las rutas con sufijo vacío también pueden aceptar la variante con barra final cuando el router lo declara explícitamente. Los permisos indicados representan el acceso efectivo esperado desde backend.

| Módulo  | Método | Ruta                   | Autenticación | Rol mínimo          | Propósito                                  |
|---------|--------|------------------------|---------------|---------------------|--------------------------------------------|
| Salud   | GET    | /                      | No            | Público             | Mensaje de API funcionando.                |
| Salud   | GET    | /health                | No            | Público             | Healthcheck básico.                        |
| Salud   | GET    | /readiness             | No            | Público controlado  | Validación de ambiente UAT/go-live.        |
| Usuario | GET    | /me                    | Sí            | Usuario autenticado | Retorna UID, email, rol y activo.          |
| Auth    | POST   | /auth/login            | Sí            | Usuario autenticado | Sincroniza usuario autenticado.            |
| Auth    | POST   | /auth/register         | Sí            | Usuario autenticado | Sincroniza usuario autenticado.            |
| Auth    | PATCH  | /auth/temporary-role   | Sí            | Dev habilitado      | Cambio temporal de rol solo en desarrollo. |
| Cientes | GET    | /clientes              | Sí            | vendedor            | Lista clientes visibles.                   |
| Cientes | POST   | /clientes              | Sí            | vendedor            | Crea cliente.                              |
| Cientes | GET    | /clientes/{cliente_id} | Sí            | vendedor            | Detalle de cliente.                        |
| Cientes | PATCH  | /clientes/{cliente_id} | Sí            | vendedor            | Edita cliente.                             |
| Cientes | DELETE | /clientes/{cliente_id} | Sí            | vendedor            | Baja lógica sin contenido.                 |
| Cientes | POST   | /clientes/import-csv   | Sí            | admin               | Importación masiva CSV.                    |

| Módulo      | Método | Ruta                                    | Autenticación | Rol mínimo    | Propósito                                |
|-------------|--------|-----------------------------------------|---------------|---------------|------------------------------------------|
| Comercial   | GET    | /interacciones                          | Sí            | vendedor      | Lista interacciones.                     |
| Comercial   | POST   | /interacciones                          | Sí            | vendedor      | Crea interacción.                        |
| Comercial   | GET    | /oportunidades                          | Sí            | vendedor      | Lista oportunidades.                     |
| Comercial   | POST   | /oportunidades                          | Sí            | vendedor      | Crea oportunidad.                        |
| Comercial   | PATCH  | /oportunidades/{oportunidad_id}         | Sí            | vendedor      | Actualiza oportunidad.                   |
| Comercial   | GET    | /oportunidades/{oportunidad_id}/detalle | Sí            | vendedor      | Detalle enriquecido.                     |
| Comercial   | GET    | /propuestas                             | Sí            | vendedor      | Lista propuestas.                        |
| Comercial   | POST   | /propuestas                             | Sí            | vendedor      | Crea propuesta.                          |
| Comercial   | PATCH  | /propuestas/{propuesta_id}              | Sí            | vendedor      | Actualiza propuesta.                     |
| Dashboard   | GET    | /dashboard/vendedor                     | Sí            | vendedor      | Métricas propias.                        |
| Dashboard   | GET    | /dashboard/supervisor                   | Sí            | supervisor    | Métricas consolidadas.                   |
| Usuarios    | GET    | /users/                                 | Sí            | supervisor    | Lista usuarios.                          |
| Usuarios    | GET    | /users/{uid}                            | Sí            | supervisor    | Detalle usuario.                         |
| Usuarios    | PATCH  | /users/me/preferences                   | Sí            | usuario       | Actualiza preferencias propias.          |
| Usuarios    | PATCH  | /users/{uid}                            | Sí            | admin         | Actualiza usuario completo permitido.    |
| Usuarios    | PATCH  | /users/{uid}/role                       | Sí            | admin         | Actualiza rol.                           |
| Usuarios    | PATCH  | /users/{uid}/status                     | Sí            | admin         | Activa o desactiva usuario.              |
| Competencia | GET    | /competencia/repository                 | Sí            | supervisor    | Repositorio de inteligencia competitiva. |
| RAG         | POST   | /rag/chat                               | Sí            | vendedor      | Consulta Enci Chat.                      |
| RAG         | GET    | /rag/conversations                      | Sí            | vendedor      | Lista conversaciones.                    |
| RAG         | POST   | /rag/documents/upload                   | Sí            | admin         | Carga documento.                         |
| RAG         | POST   | /rag/documents/reindex                  | Sí            | admin         | Reconstruye índice.                      |
| RAG         | GET    | /rag/documents                          | Sí            | admin         | Lista documentos.                        |
| Testing     | GET    | /docs                                   | No            | No producción | Consola Swagger con login Firebase.      |
| Testing     | GET    | /openapi.json                           | No            | No producción | Esquema OpenAPI.                         |
| Testing     | GET    | /docs/guia-presentacion-frontend.pdf    | No            | No producción | Guía PDF de pruebas.                     |

## 5. Endpoints de salud, ambiente y usuario actual

Estos endpoints permiten verificar disponibilidad básica, condiciones mínimas de salida y estado del usuario autenticado. Deben usarse en smoke tests y validaciones previas a UAT.

| Método | Ruta | Entrada  | Respuesta esperada                  | Uso UAT             |
|--------|------|----------|-------------------------------------|---------------------|
| GET    | /    | Sin body | { message: 'Enci API funcionando' } | Confirmar API viva. |

| Método | Ruta       | Entrada      | Respuesta esperada               | Uso UAT                                      |
|--------|------------|--------------|----------------------------------|----------------------------------------------|
| GET    | /health    | Sin body     | { status: 'ok' }                 | Healthcheck rápido post despliegue.          |
| GET    | /readiness | Sin body     | status, env, version y checks    | Validar Firebase, CORS, DeepSeek y ambiente. |
| GET    | /me        | Bearer token | uid, email, rol, activo, message | Confirmar token y rol efectivo.              |

## 5.1 Contrato de /me

```
GET /me
Authorization: Bearer <firebase_id_token>

Respuesta 200:
{
  "uid": "firebase-uid",
  "email": "usuario@dominio.cl",
  "rol": "vendedor",
  "activo": true,
  "message": "Token valido"
}
```

## 6. Contratos de autenticación

Los endpoints de autenticación sincronizan al usuario validado contra Firebase y Firestore. No reciben correo o contraseña del cliente; dependen del ID Token Firebase previamente emitido por Google SSO.

| Método | Ruta                 | Body                    | Regla                                                   | Respuesta                 |
|--------|----------------------|-------------------------|---------------------------------------------------------|---------------------------|
| POST   | /auth/login          | No requiere body propio | Valida token y crea/actualiza users/{uid}.              | UserResponse.             |
| POST   | /auth/register       | No requiere body propio | Mismo flujo de sincronización que login.                | UserResponse.             |
| PATCH  | /auth/temporary-role | { rol }                 | Solo development y ENABLE_TEMPORARY_ROLE_SWITCHER=true. | UserResponse y audit log. |

### Restricción crítica

El endpoint /auth/temporary-role no forma parte de la operación productiva. Debe permanecer deshabilitado fuera de development y no debe usarse como mecanismo formal de administración de usuarios.

## 6.1 UserResponse

```
{
  "uid": "firebase-uid",
  "email": "usuario@dominio.cl",
  "nombre": "Usuario Enci",
  "rol": "sin_acceso | admin | supervisor | vendedor",
  "cargo": "Sin acceso | texto operativo",
  "rango": "Sin acceso | Solo lectura | Vendedor | Gerente | Administrador",
  "zona": "Zona norte | Zona centro | Zona sur | Zona oriente",
  "appMovil": true,
  "webApp": true,
  "theme": "dark | light",
  "language": "es | en | pt",
  "activo": true,
  "createdAt": "datetime opcional",
  "updatedAt": "datetime opcional"
}
```

## 7. Contratos del módulo Clientes

El módulo Clientes centraliza la gestión CRM de empresas, contactos y estado comercial. Los vendedores solo ven y modifican clientes asociados a su UID; supervisor y admin tienen visibilidad superior según la lógica de servicio.

| Método | Ruta                   | Query / Body                       | Rol mínimo | Respuesta                    |
|--------|------------------------|------------------------------------|------------|------------------------------|
| GET    | /clientes              | search, estado, vendedorUid, limit | vendedor   | Lista ClienteResponse.       |
| POST   | /clientes              | ClienteCreate                      | vendedor   | ClienteResponse creado.      |
| GET    | /clientes/{cliente_id} | Path cliente_id                    | vendedor   | ClienteResponse.             |
| PATCH  | /clientes/{cliente_id} | ClienteUpdate                      | vendedor   | ClienteResponse actualizado. |
| DELETE | /clientes/{cliente_id} | Path cliente_id                    | vendedor   | 204 No Content.              |
| POST   | /clientes/import-csv   | multipart/form-data file           | admin      | CsvImportResult.             |

### 7.1 Query params de listado

| Parámetro   | Tipo            | Regla                | Descripción                                                      |
|-------------|-----------------|----------------------|------------------------------------------------------------------|
| search      | string opcional | máx. 80              | Búsqueda textual.                                                |
| estado      | string opcional | máx. 32              | Filtro por estado.                                               |
| vendedorUid | string opcional | máx. 128             | Filtro por vendedor; vendedores quedan forzados a su propio uid. |
| limit       | int             | 1 a 500; default 100 | Cantidad máxima de resultados.                                   |

### 7.2 ClienteCreate



```
{
  "nombre": "Nombre contacto",
  "empresa": "Empresa cliente",
  "email": "contacto@empresa.cl",
  "telefono": "912345678 | +56912345678 | opcional",
  "rubro": "Agroindustrial | opcional",
  "region": "Región | opcional",
  "estado": "En proceso | Completado | Inactivo",
  "vendedorUid": "uid opcional",
  "ownerUid": "uid opcional"
}
```

| Campo                  | Validación principal                                                          |
|------------------------|-------------------------------------------------------------------------------|
| nombre                 | Obligatorio, 1 a 120 caracteres, rechaza prefijos de fórmula.                 |
| empresa                | Obligatorio, 1 a 160 caracteres, rechaza prefijos de fórmula.                 |
| email                  | Formato EmailStr válido.                                                      |
| telefono               | Opcional; normaliza móvil chileno a 8 dígitos después de +569.                |
| rubro                  | Opcional, máximo 120 caracteres, rechaza prefijos de fórmula.                 |
| region                 | Opcional, máximo 80 caracteres, rechaza prefijos de fórmula.                  |
| estado                 | Literal: En proceso, Completado o Inactivo.                                   |
| vendedorUid / ownerUid | Opcional, máximo 128 caracteres; vendedor no puede reasignar propiedad ajena. |

## 7.3 CsvImportResult

```
{
  "totalFilas": 25,
  "importados": 22,
  "fallidos": 3,
  "errores": [
    { "fila": 4, "errores": ["email inválido", "duplicado funcional"] }
  ]
}
```

# 8. Contratos del flujo comercial

El flujo comercial cubre interacciones, oportunidades y propuestas. Estos contratos vinculan actividades a clientes visibles, aplican reglas de propiedad y calculan montos sensibles en backend.

## 8.1 Interacciones

| Método | Ruta           | Query / Body                               | Respuesta                     |
|--------|----------------|--------------------------------------------|-------------------------------|
| GET    | /interacciones | clientId opcional, limit 1-500 default 100 | Lista<br>InteractionResponse. |
| POST   | /interacciones | InteractionCreate                          | InteractionResponse.          |

```

InteractionCreate:
{
  "clienteId": "cliente-id",
  "tipo": "llamada | visita | correo | reunion",
  "fecha": "2026-07-06T10:30:00Z",
  "resumen": "Resumen de la interacción",
  "resultado": "Resultado opcional",
  "proximaAccion": "Acción siguiente opcional"
}

InteractionResponse agrega:
{
  "id": "interaction-id",
  "vendedorUid": "uid",
  "createdAt": "datetime opcional",
  "updatedAt": "datetime opcional"
}

```

## 8.2 Oportunidades

| Método | Ruta                                    | Query / Body                                    | Respuesta                  |
|--------|-----------------------------------------|-------------------------------------------------|----------------------------|
| GET    | /oportunidades                          | clienteId opcional, etapa opcional, limit 1-500 | Lista OpportunityResponse. |
| POST   | /oportunidades                          | OpportunityCreate                               | OpportunityResponse.       |
| PATCH  | /oportunidades/{oportunidad_id}         | OpportunityUpdate                               | OpportunityResponse.       |
| GET    | /oportunidades/{oportunidad_id}/detalle | Path oportunidad_id                             | OpportunityDetailResponse. |

```

OpportunityCreate:
{
  "clienteId": "cliente-id",
  "titulo": "Renovación de suministro",
  "etapa": "nuevo | contactado | cotizacion | negociacion | ganado | perdido",
  "valorEstimado": 2500000,
  "probabilidad": 60,
  "descripcion": "Descripción opcional"
}

OpportunityUpdate permite actualizar:
{
  "titulo": "texto opcional",
  "etapa": "valor opcional",
  "valorEstimado": 0 a 1000000000,
  "probabilidad": 0 a 100,
  "descripcion": "texto opcional"
}

```

## 8.3 Propuestas

| Método | Ruta                       | Query / Body                            | Respuesta               |
|--------|----------------------------|-----------------------------------------|-------------------------|
| GET    | /propuestas                | clienteId, estado, oportunidadId, limit | Lista ProposalResponse. |
| POST   | /propuestas                | ProposalCreate                          | ProposalResponse.       |
| PATCH  | /propuestas/{propuesta_id} | ProposalUpdate                          | ProposalResponse.       |

```

ProposalCreate:
{
  "clienteId": "cliente-id",
  "oportunidadId": "oportunidad-id",
  "titulo": "Propuesta comercial",
  "montoNeto": 1000000,
  "descuentoPct": 10,
  "estado": "borrador | enviada | aceptada | rechazada",
  "notas": "texto opcional"
}

```

ProposalResponse agrega cálculo server-side:

```

{
  "id": "propuesta-id",
  "vendedorUid": "uid",
  "montoDescuento": 100000,
  "montoTotal": 900000,
  "createdAt": "datetime opcional",
  "updatedAt": "datetime opcional"
}

```

| Validación        | Detalle                                                                                                             |
|-------------------|---------------------------------------------------------------------------------------------------------------------|
| Formula injection | clienteId, título, descripción, resumen, notas y campos de texto rechazan prefijos =, +, - y @ cuando aplica.       |
| Etapas            | Se normalizan alias como prospecto/prospección a nuevo, propuesta enviada a cotización y negociación a negociacion. |
| Estados           | Se normalizan alias como ganada a aceptada y perdida a rechazada.                                                   |
| Monto             | montoNeto y valorEstimado tienen tope 1.000.000.000; descuentoPct va entre 0 y 100.                                 |
| Probabilidad      | probabilidad va entre 0 y 100.                                                                                      |

## 9. Contratos de dashboard y analítica

Los endpoints de dashboard entregan métricas calculadas desde los datos comerciales. El dashboard de vendedor trabaja con alcance propio; el dashboard de supervisor entrega visión consolidada del equipo.

| Método | Ruta                  | Rol mínimo | Entrada      | Respuesta                                       |
|--------|-----------------------|------------|--------------|-------------------------------------------------|
| GET    | /dashboard/vendedor   | vendedor   | Bearer token | DashboardResponse filtrado por uid del usuario. |
| GET    | /dashboard/supervisor | supervisor | Bearer token | DashboardResponse consolidado.                  |

### 9.1 Uso esperado

- El vendedor debe ver métricas propias sin poder forzar métricas de otro vendedor mediante query params.
- Supervisor y admin pueden acceder a métricas consolidadas del equipo.
- El endpoint debe usarse para validar KPIs de clientes, oportunidades, propuestas, forecast y alertas visibles en frontend.

- La exactitud final de indicadores depende de datos reales, reglas comerciales confirmadas y UAT.

## 10. Contratos de usuarios, roles y preferencias

El módulo de usuarios separa consultas operativas, preferencias personales y cambios administrativos sensibles. Los listados y detalles requieren rol supervisor; los cambios de rol, estado y edición general requieren admin.

| Método | Ruta                  | Rol mínimo          | Body / Query                 | Resultado                 |
|--------|-----------------------|---------------------|------------------------------|---------------------------|
| GET    | /users/               | supervisor          | activo opcional, limit 1-500 | Lista UserResponse.       |
| GET    | /users/{uid}          | supervisor          | Path uid                     | UserResponse.             |
| PATCH  | /users/me/preferences | usuario autenticado | UserPreferencesUpdate        | UserResponse propio.      |
| PATCH  | /users/{uid}          | admin               | UserUpdate                   | UserResponse actualizado. |
| PATCH  | /users/{uid}/role     | admin               | UserRoleUpdate               | UserResponse actualizado. |
| PATCH  | /users/{uid}/status   | admin               | UserStatusUpdate             | UserResponse actualizado. |

### 10.1 Payloads principales

```
UserPreferencesUpdate:
{
  "theme": "dark | light",
  "language": "es | en | pt"
}

UserRoleUpdate:
{ "rol": "sin_acceso | admin | supervisor | vendedor" }

UserStatusUpdate:
{ "activo": true }

UserUpdate permite actualizar:
{
  "nombre": "Nombre normalizado",
  "lookupEmail": "correo@dominio.cl",
  "rol": "admin | supervisor | vendedor | sin_acceso",
  "cargo": "texto",
  "rango": "Sin acceso | Solo lectura | Vendedor | Gerente | Administrador",
  "zona": "Zona norte | Zona centro | Zona sur | Zona oriente",
  "appMovil": true,
  "webApp": true,
  "theme": "dark | light",
  "language": "es | en | pt",
  "activo": true
}
```

## 11. Contratos de competencia e inteligencia comercial

El endpoint de competencia entrega repositorio de datos para análisis comercial e inteligencia competitiva. Su consulta se restringe a supervisor o admin por jerarquía de roles, dado que contiene información agregada y sensible para gestión.

| Método | Ruta                    | Rol mínimo | Respuesta                     | Uso                                                                 |
|--------|-------------------------|------------|-------------------------------|---------------------------------------------------------------------|
| GET    | /competencia/repository | supervisor | CompetitionRepositoryResponse | Poblar pantallas de análisis competitivo e inteligencia de mercado. |

#### Alcance

El repositorio de competencia depende de datos cargados o definidos por el negocio. Nuevas reglas de captura, scraping, integraciones externas o inteligencia competitiva avanzada deben tratarse como evolución posterior si no están comprometidas en el MVP.

## 12. Contratos del módulo IA RAG

El módulo IA RAG opera como componente parcial con DeepSeek, Chroma, documentos indexados y contexto interno. Se entrega el estado actual del componente; no implica tuning, reentrenamiento, cambio de proveedor, evaluación avanzada de calidad ni garantía de SLA externo.

| Método | Ruta                   | Rol mínimo | Body / Query             | Respuesta                      |
|--------|------------------------|------------|--------------------------|--------------------------------|
| POST   | /rag/chat              | vendedor   | RagChatRequest           | RagChatResponse.               |
| GET    | /rag/conversations     | vendedor   | limit 1-100 default 50   | Lista RagConversationResponse. |
| POST   | /rag/documents/upload  | admin      | multipart/form-data file | RagUploadResponse.             |
| POST   | /rag/documents/reindex | admin      | Sin body                 | mensaje y chunks_indexados.    |
| GET    | /rag/documents         | admin      | Sin body                 | Lista RagDocumentResponse.     |

### 12.1 RagChatRequest y RagChatResponse

```

RagChatRequest:
{
  "pregunta": "consulta técnica, comercial o documental",
  "conversacion_id": "uuid-opcional"
}

Reglas:
- pregunta obligatoria, 1 a 1000 caracteres.
- conversacion_id opcional, máximo 128 caracteres.
- la pregunta se sanitiza y no puede quedar vacía.

RagChatResponse:
{
  "respuesta": "texto generado o respuesta local sin contexto",
  "fuentes": [
    { "documento": "archivo.pdf", "pagina": 3, "fragmento": "texto usado" }
  ],
  "conversacion_id": "uuid",
  "tokens_usados": 512,
  "timestamp": "datetime",
  "diagnostico": {
    "origen": "deepseek | local | other",
    "proveedor": "DeepSeek | Motor local Enci",
    "modelo": "deepseek-chat",
    "fragmentos_documentales": 3,
    "fragmentos_internos": 1
  },
  "titulo_conversacion": "título opcional"
}

```

## 12.2 Contratos documentales RAG

| Contrato            | Campos / reglas                                                                                                  |
|---------------------|------------------------------------------------------------------------------------------------------------------|
| RagDocumentResponse | id, nombre, nombreOriginal, descripcion, gcsPath, chunks_count, subidoPor, subidoPorEmail, tamaño_bytes, activo. |
| RagUploadResponse   | mensaje, documento, chunks_indexados, disponible_en=inmediato.                                                   |
| Formatos aceptados  | PDF, DOCX y TXT UTF-8 según validación documental.                                                               |
| Tamaño              | Máximo definido por RAG_MAX_UPLOAD_BYTES; referencia de cierre: 20 MB.                                           |
| Seguridad           | DEEPSEEK_API_KEY solo en backend. No debe existir en frontend ni variables VITE*.                                |

## 13. Consola Swagger / OpenAPI y documentación técnica

La consola /docs permite probar endpoints protegidos con login Google y token Firebase aplicado al esquema HTTPBearer. Está pensada para desarrollo, UAT técnico y validación controlada, no para exposición pública en producción.

| Ruta  | Disponibilidad | Propósito                                                      |
|-------|----------------|----------------------------------------------------------------|
| /docs | No producción  | Swagger UI con login Google, token aplicado y guía de pruebas. |

| Ruta                                 | Disponibilidad | Propósito                              |
|--------------------------------------|----------------|----------------------------------------|
| /openapi.json                        | No producción  | Esquema OpenAPI consumido por Swagger. |
| /docs/guia-presentacion-frontend.pdf | No producción  | Guía PDF de presentación y pruebas.    |

### 13.1 Flujo de prueba en Swagger

- Abrir /docs en ambiente autorizado y no productivo.
- Presionar Login con Google y seleccionar una cuenta autorizada en Firebase.
- Validar que el token quede aplicado automáticamente al esquema HTTPBearer.
- Ejecutar primero /me para confirmar rol, uid y estado activo.
- Probar endpoints según rol: /clientes, /dashboard, /users y /rag según corresponda.
- Registrar cualquier 401, 403, 422, 429 o 503 como evidencia de prueba y distinguir error de permisos, payload, cuota o ambiente.

## 14. Parámetros, modelos y validaciones transversales

Los contratos de entrada aplican validaciones comunes para reducir errores operativos, entradas maliciosas y comportamientos inconsistentes entre frontend, backend y consumidores móviles.

| Categoría          | Regla                                                                   | Endpoints afectados                                 |
|--------------------|-------------------------------------------------------------------------|-----------------------------------------------------|
| Campos extra       | ConfigDict(extra='forbid') rechaza campos no declarados.                | Clientes, comercial, usuarios, RAG request.         |
| Formula injection  | Campos de texto no deben iniciar con =, +, - o @.                       | Clientes, interacciones, oportunidades, propuestas. |
| Email              | EmailStr exige formato válido.                                          | Clientes y usuarios.                                |
| Teléfono           | Móvil chileno normalizado a 8 dígitos después de +569.                  | Clientes.                                           |
| Límites de listado | limit entre 1 y 500 en listados principales; RAG conversations 1 a 100. | Clientes, comercial, usuarios, RAG.                 |
| Montos             | montoNeto, valorEstimado y descuentos con rangos definidos.             | Oportunidades y propuestas.                         |
| Estados literales  | Roles, etapas, estados, theme, language y zonas usan listas cerradas.   | Usuarios, comercial, clientes.                      |
| Carga documental   | Extensión, contenido real y tamaño máximo.                              | RAG upload y CSV clientes.                          |

### 14.1 Listas cerradas principales

| Dominio         | Valores permitidos                |
|-----------------|-----------------------------------|
| ClienteEstado   | En proceso, Completado, Inactivo. |
| InteractionType | llamada, visita, correo, reunion. |

| Dominio          | Valores permitidos                                           |
|------------------|--------------------------------------------------------------|
| OpportunityStage | nuevo, contactado, cotizacion, negociacion, ganado, perdido. |
| ProposalStatus   | borrador, enviada, aceptada, rechazada.                      |
| UserRole         | sin_acceso, admin, supervisor, vendedor.                     |
| UserRank         | Sin acceso, Solo lectura, Vendedor, Gerente, Administrador.  |
| UserZone         | Zona norte, Zona centro, Zona sur, Zona oriente.             |
| UserTheme        | dark, light.                                                 |
| UserLanguage     | es, en, pt.                                                  |

## 15. Errores esperados y respuestas de control

Los errores esperados permiten diagnosticar correctamente fallas de autenticación, permisos, datos inválidos, conflictos funcionales, rate limit, cuotas o indisponibilidad externa. No todos los errores indican bug; algunos son controles de seguridad esperados.

| Código | Caso                                                                          | Interpretación operativa                                                 |
|--------|-------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| 400    | Regla de negocio inválida.                                                    | El request es válido a nivel sintáctico, pero viola una regla funcional. |
| 401    | Token ausente, inválido o expirado.                                           | Debe iniciar sesión nuevamente o enviar Authorization Bearer correcto.   |
| 403    | Rol insuficiente, usuario inactivo, sin acceso a plataforma o registro ajeno. | Control de autorización funcionando.                                     |
| 404    | Ruta o recurso inexistente.                                                   | ID no encontrado, endpoint no disponible o docs oculto en producción.    |
| 409    | Duplicado funcional, por ejemplo email activo.                                | Conflicto de negocio a corregir.                                         |
| 422    | Payload inválido, campo extra, tipo incorrecto o rango fuera de límite.       | Debe corregirse contrato enviado.                                        |
| 429    | Rate limit, exceso de consultas RAG o cuota Firestore.                        | Esperar ventana de reintento o revisar consumo.                          |
| 503    | Firestore, proveedor externo o servicio de datos no disponible.               | Falla temporal de infraestructura/proveedor.                             |

### 15.1 Diagnóstico rápido

- 401 se revisa primero desde login, expiración del token o ausencia del header Authorization.
- 403 se revisa desde rol, activo, webApp/appMovil y propiedad del registro.
- 422 se revisa desde el JSON enviado, nombres de campos, tipos, longitudes y valores literales permitidos.
- 429 se revisa desde frecuencia de uso, pruebas automatizadas repetidas o cuota Firestore/proveedor.
- 503 se revisa desde conectividad con Firestore, credenciales, proveedor DeepSeek o indisponibilidad externa.



## 16. Matriz de trazabilidad por módulo

La trazabilidad vincula módulos funcionales con endpoints, modelos y evidencia esperada para recepción. Esta matriz permite organizar pruebas y verificar que cada flujo crítico tenga contrato documentado.

| Módulo        | Endpoints clave                                 | Modelos principales                                            | Evidencia esperada                                          |
|---------------|-------------------------------------------------|----------------------------------------------------------------|-------------------------------------------------------------|
| Autenticación | /auth/login, /auth/register, /me                | UserResponse                                                   | Login Google, token válido y usuario sincronizado.          |
| Cientes       | /clientes, /clientes/{id}, /clientes/import-csv | ClienteCreate, ClienteUpdate, ClienteResponse, CsvImportResult | Crear, listar, filtrar, editar, baja lógica e importar CSV. |
| Interacciones | /interacciones                                  | InteractionCreate, InteractionResponse                         | Registrar y listar contactos comerciales.                   |
| Oportunidades | /oportunidades, /oportunidades/{id}/detalle     | OpportunityCreate, OpportunityUpdate, OpportunityResponse      | Crear, cambiar etapa y revisar detalle.                     |
| Propuestas    | /propuestas, /propuestas/{id}                   | ProposalCreate, ProposalUpdate, ProposalResponse               | Crear propuesta y validar cálculo server-side.              |
| Dashboard     | /dashboard/vendedor, /dashboard/supervisor      | DashboardResponse                                              | Métricas propias y consolidadas.                            |
| Usuarios      | /users, /users/{uid}, role, status, preferences | UserUpdate, UserRoleUpdate, UserStatusUpdate                   | Listar usuarios y administrar rol/estado/accesos.           |
| Competencia   | /competencia/repository                         | CompetitionRepositoryResponse                                  | Acceder a repositorio competitivo según rol.                |
| RAG           | /rag/chat, /rag/conversations, /rag/documents/* | RagChatRequest, RagChatResponse, RagDocumentResponse           | Consultar Enci Chat, revisar fuentes y administrar corpus.  |
| Testing       | /docs, /openapi.json                            | OpenAPI                                                        | Probar endpoints con token Firebase.                        |

## 17. Criterios de aceptación del anexo

Este anexo se considera aceptable si permite ejecutar pruebas técnicas, comprender los contratos de entrada/salida, distinguir permisos por rol y diagnosticar errores esperados durante UAT o soporte.

| Código | Criterio                                                                                       | Resultado esperado                                                      |
|--------|------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| CA-C01 | La matriz incluye endpoints públicos, protegidos, administrativos, comerciales, RAG y testing. | La superficie API queda identificada.                                   |
| CA-C02 | Se documenta Authorization Bearer y X-Enci-Client.                                             | Los consumidores conocen cómo autenticarse y declarar plataforma.       |
| CA-C03 | Se especifican roles mínimos y jerarquía de acceso.                                            | UAT puede validar 401/403 correctamente.                                |
| CA-C04 | Se describen contratos de clientes, comercial, usuarios, dashboard, competencia y RAG.         | Frontend, PWA, Flutter y Swagger pueden consumir API con reglas claras. |
| CA-C05 | Se incluyen validaciones transversales y listas cerradas.                                      | Se reducen errores de payload y ambigüedad de estados.                  |

| Código | Criterio                                                                                 | Resultado esperado                                                                      |
|--------|------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| CA-C06 | Se explican errores 400, 401, 403, 404, 409, 422, 429 y 503.                             | Soporte puede distinguir falla real de control esperado.                                |
| CA-C07 | Se reconoce RAG como componente parcial y Flutter como consumidor móvil parcial externo. | La recepción no confunde ausencia de Flutter en GitHub con inexistencia del entregable. |

## 17.1 Recomendaciones para pruebas

- Probar primero /health, /readiness y /me antes de flujos de negocio.
- Usar usuarios de prueba diferenciados: vendedor, supervisor, admin, inactivo y sin\_acceso.
- Validar que vendedor no acceda a cliente, oportunidad, interacción o propuesta ajena.
- Validar que endpoints admin rechacen usuarios vendedor/supervisor cuando corresponda.
- Ejecutar pruebas negativas de payload: campos extra, estado inválido, montos fuera de rango y texto con prefijo de fórmula.
- Probar RAG con pregunta con contexto, sin contexto, documento cargado y límite de uso.
- Registrar evidencia de respuestas 200/201/204 y errores 401/403/422 como parte del plan UAT.

### Cierre del anexo

La matriz de endpoints y contratos API documenta la base técnica para pruebas, integración y soporte del MVP web avanzado. Los contratos aquí descritos deben evaluarse junto con roles reales, ambiente configurado, datos válidos y alcance parcial documentado para IA RAG y app Flutter.